Задание 1. Разработка организационно-распорядительных документов по информационной безопасности

ДОКУМЕНТ 1: ПОЛОЖЕНИЕ

ПОЛОЖЕНИЕ

об организации планирования мероприятий по обеспечению защиты информации и повышения осведомлённости персонала компании «Ромашка»

Раздел 1. Общие положения

1.1. Назначение и область применения

1.1.1. Настоящее Положение определяет порядок организации планирования мероприятий по обеспечению информационной безопасности (далее — ИБ), а также обучения и повышения осведомлённости персонала компании «Ромашка» (далее — Компания).

1.1.2. Положение обязательно для исполнения всеми структурными подразделениями и работниками Компании.

1.2. Основные термины и определения

- Информационная безопасность (ИБ) — состояние защищённости информационных ресурсов Компании от внутренних и внешних угроз.
- План мероприятий по обеспечению ИБ — документ, определяющий перечень, сроки и ответственных за выполнение организационных и технических мероприятий по защите информации.
- Повышение осведомлённости — комплекс мероприятий, направленных на формирование у работников Компании культуры информационной безопасности.

1.3. Нормативные акты, используемые при подготовке документа

- Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных».
- Приказ ФСТЭК России от 18.02.2013 № 21.
- Политика компании «Ромашка» в отношении обработки персональных данных.

Раздел 2. Основная часть

2.1. Структурные подразделения (работники), ответственные за разработку планов мероприятий по обеспечению безопасности

2.1.1. Общее руководство и координацию деятельности по планированию мероприятий по обеспечению ИБ осуществляет лицо, ответственное за организацию обработки персональных данных (далее — Ответственный за ИБ).

2.1.2. Непосредственную разработку проектов планов мероприятий осуществляет подразделение информационной безопасности (далее — Подразделение ИБ).

2.1.3. Руководители структурных подразделений Компании несут ответственность за предоставление в Подразделение ИБ предложений по мероприятиям, необходимым для обеспечения ИБ в их подразделениях.

2.2. Требования по организации ежегодного планирования мероприятий по обеспечению безопасности

2.2.1. Планирование мероприятий по обеспечению ИБ осуществляется на ежегодной основе. План разрабатывается на очередной календарный год не позднее 1 декабря предшествующего года.

2.2.2. Процесс планирования включает следующие этапы:

- Сбор предложений от руководителей структурных подразделений (до 15 ноября);
- Анализ результатов аудита ИБ и инцидентов за отчётный период;
- Формирование проекта Плана мероприятий Подразделением ИБ (до 25 ноября);
- Согласование проекта Плана с руководителями ключевых подразделений и юристами Компании (до 5 декабря);
- Утверждение Плана генеральным директором Компании (до 15 декабря).

2.2.3. В течение года допускается внесение изменений в утверждённый План в случае:

- изменения бизнес-процессов Компании;
- изменения требований законодательства;
- выявления новых угроз информационной безопасности;
- возникновения инцидентов ИБ, требующих дополнительных мер.

2.3. Требования к разработке планов мероприятий по обеспечению безопасности

2.3.1. План мероприятий по обеспечению ИБ должен содержать:

- Перечень мероприятий (организационных, технических, правовых);
- Сроки выполнения каждого мероприятия;
- Ответственных исполнителей;
- Необходимые ресурсы (финансовые, трудовые, технические);
- Критерии успешного выполнения мероприятий.

2.3.2. Мероприятия Плана должны охватывать следующие направления:

- Защита персональных данных и конфиденциальной информации;
- Антивирусная защита и защита от вредоносного ПО;
- Управление доступом и идентификация пользователей;
- Обеспечение целостности и доступности информационных ресурсов;
- Защита каналов связи и сетевого взаимодействия;
- Физическая защита технических средств;
- Обеспечение непрерывности функционирования информационных систем.

2.3.3. Подразделение ИБ ведёт мониторинг выполнения Плана и ежеквартально предоставляет отчёт о ходе его реализации Ответственному за ИБ.
2.4. Обучение и повышение осведомлённости персонала в вопросах информационной безопасности
2.4.1. Обучение и повышение осведомлённости персонала является неотъемлемой частью системы обеспечения ИБ Компании.
2.4.2. Обучение проводится в следующих формах:

- Вводный инструктаж — для всех вновь принятых работников в течение первой рабочей недели;
- Периодическое обучение — для всех работников не реже одного раза в год;
- Целевое обучение — для работников, имеющих доступ к конфиденциальной информации и персональным данным, не реже одного раза в год;
- Внеплановое обучение — при изменении требований законодательства, внедрении новых информационных систем, возникновении инцидентов ИБ.

2.4.3. Программа обучения должна включать следующие темы:

- Основные требования законодательства в области ИБ;
- Политика Компании в отношении обработки персональных данных;
- Правила парольной защиты и управления учётными записями;
- Действия при обнаружении признаков вредоносного ПО;
- Порядок реагирования на инциденты ИБ;
- Правила работы со съёмными носителями информации;
- Противодействие методам социальной инженерии (фишинг, фарминг и др.).

2.4.4. Подразделение ИБ разрабатывает ежегодный План мероприятий по обучению и повышению осведомлённости персонала, который утверждается Ответственным за ИБ.
2.4.5. Результаты обучения фиксируются в Журнале прохождения обучения работников вопросам обеспечения ИБ.
2.4.6. Для повышения осведомлённости персонала Подразделение ИБ организует:

- Рассылку информационных бюллетеней по вопросам ИБ (ежеквартально);
- Размещение памяток и инструкций на корпоративном портале;
- Проведение тематических семинаров и вебинаров;
- Тестирование знаний работников по вопросам ИБ.

Раздел 3. Заключительная часть

3.1. Контроль и ответственность
3.1.1. Контроль за выполнением требований настоящего Положения осуществляет Ответственный за ИБ.
3.1.2. Ответственность за организацию планирования мероприятий по обеспечению ИБ несёт генеральный директор Компании.
3.1.3. Ответственность за разработку, реализацию и внедрение Плана мероприятий несёт Подразделение ИБ.
3.1.4. Неисполнение или некачественное исполнение работниками Компании обязанностей по обеспечению ИБ может повлечь применение мер дисциплинарного воздействия в соответствии с действующим законодательством.

3.2. Порядок внесения изменений
3.2.1. Пересмотр Положения осуществляется:

- В плановом режиме не реже одного раза в три года;
- Во внеплановом режиме в случае изменения бизнес-процессов Компании, изменения требований законодательства, реорганизации структуры управления ИБ.

Раздел 4. Приложения

Приложение 1
Форма Плана мероприятий по обеспечению информационной безопасности

№ п/п	Наименование мероприятия	Срок выполнения	Ответственный исполнитель	Необходимые ресурсы	Критерии выполнения
1	Проведение аудита ИСПДн	I квартал	Подразделение ИБ	100 000 руб.	Отчёт об аудите
2	Обновление средств антивирусной защиты	Ежеквартально	Администратор ИБ	—	Актуальные антивирусные базы
3	Обучение работников вопросам ИБ	II, IV кварталы	Подразделение ИБ	50 000 руб.	Журнал обучения

Приложение 2
Форма Плана мероприятий по обучению и повышению осведомлённости персонала

№ п/п	Категория работников	Тема обучения	Форма обучения	Срок проведения	Ответственный
1	Вновь принятые работники	Вводный инструктаж по ИБ	Очное обучение	В течение 1 недели	Подразделение ИБ
2	Все работники	Основы защиты ПДн	Онлайн-курс	II квартал	Подразделение ИБ

3	Работники с доступом к ПДн	Противодействие фишингу	Семинар	IV квартал	Подразделение ИБ

Утверждено: _____ (Подпись)

Дата: _____._____.20___ г.

ДОКУМЕНТ 2: РЕГЛАМЕНТ

РЕГЛАМЕНТ

реагирования на компьютерные инциденты в компании «Ромашка»

Раздел 1. Общие положения

1.1. Назначение
1.1.1. Настоящий Регламент определяет систему организационно-технических мероприятий по обнаружению, реагированию, расследованию и устранению последствий инцидентов информационной безопасности (далее — ИБ) в компании «Ромашка» (далее — Компания).
1.2. Область применения
1.2.1. Регламент распространяет своё действие на все информационные системы персональных данных (ИСПДн) и информационные ресурсы Компании, а также на всех работников и сторонние организации, участвующие в эксплуатации и защите информационных ресурсов.
1.3. Нормативные акты, используемые при подготовке документа
- Политика компании «Ромашка» в отношении обработки персональных данных;
- Положение по антивирусной защите;
- Положение по обеспечению непрерывности функционирования информационных ресурсов.

1.4. Понятия, определения, сокращения
- Инцидент ИБ — событие или серия событий, которые приводят или могут привести к нарушению конфиденциальности, целостности или доступности информации.
- Компьютерный инцидент — инцидент ИБ, связанный с использованием информационных технологий и средств вычислительной техники.

- Группа реагирования на инциденты (ГРИ) — специально назначенная группа работников, ответственная за реагирование на инциденты ИБ.

Раздел 2. Основная часть

2.1. Роли и функции работников по реагированию на компьютерные инциденты
2.1.1. В процессе реагирования на компьютерные инциденты участвуют следующие роли:
Руководитель ГРИ (Ответственный за ИБ):

- Общее руководство процессом реагирования на инциденты;
- Принятие решений о классификации и приоритете инцидентов;
- Координация действий участников ГРИ;
- Взаимодействие с руководством Компании и внешними организациями.

Аналитики ГРИ (специалисты Подразделения ИБ):

- Обнаружение и первичный анализ инцидентов;
- Сбор и регистрация событий ИБ;
- Проведение расследования инцидентов;
- Разработка рекомендаций по устранению последствий.

Администраторы ИСПДн:

- Техническое реагирование на инциденты;
- Блокирование учётных записей, изоляция заражённых систем;
- Восстановление работоспособности информационных систем;
- Предоставление журналов событий и технической информации.

Пользователи ИСПДн:

- Немедленное информирование ГРИ о подозрительных событиях;
- Сохранение доказательств инцидента (не выключать компьютер, не удалять файлы);
- Выполнение указаний ГРИ в процессе реагирования.

2.2. Классификация и ранжирование инцидентов
2.2.1. Инциденты ИБ классифицируются по следующим категориям:
Категория 1 — Критические инциденты:

- Массовое заражение информационных систем вредоносным ПО;
- Несанкционированный доступ к базам данных с персональными данными;
- Отказ в обслуживании критических информационных систем;
- Утечка конфиденциальной информации большого объёма;
- Физическое уничтожение или хищение серверов, носителей информации.

Категория 2 — Серьёзные инциденты:

- Заражение отдельных рабочих станций вредоносным ПО;
- Несанкционированный доступ к информационным системам без извлечения данных;
- Нарушение доступности некритических информационных систем;
- Утечка конфиденциальной информации ограниченного объёма;
- Потеря съёмных носителей информации.

Категория 3 — Незначительные инциденты:

- Попытки несанкционированного доступа, заблокированные средствами защиты;

- Обнаружение вредоносного ПО, нейтрализованного антивирусными средствами;
- Кратковременные сбои в работе информационных систем;
- Нарушения правил ИБ работниками (без утечки информации).

2.2.2. Приоритет реагирования определяется категорией инцидента:

- Приоритет 1 (Категория 1) — немедленное реагирование, круглосуточный режим работы ГРИ;
- Приоритет 2 (Категория 2) — реагирование в течение 2 часов в рабочее время;
- Приоритет 3 (Категория 3) — реагирование в течение рабочего дня.

2.3. Организация сбора и регистрации событий информационной безопасности

2.3.1. Сбор событий ИБ осуществляется автоматически средствами защиты информации (антивирусные средства, межсетевые экраны, системы обнаружения вторжений) и вручную (сообщения пользователей, результаты аудита).

2.3.2. Все события ИБ регистрируются в Журнале регистрации инцидентов безопасности (Приложение 1) не позднее 1 часа с момента их обнаружения.

2.3.3. При регистрации инцидента фиксируются следующие данные:

- Дата и время обнаружения;
- Источник информации об инциденте;
- Краткое описание инцидента;
- Затронутые информационные системы и ресурсы;
- Предварительная категория и приоритет;
- ФИО и должность лица, обнаружившего инцидент.

2.4. Порядок обнаружения инцидентов информационной безопасности и реагирования на них

2.4.1. Обнаружение инцидента:

Пользователь, обнаруживший признаки инцидента (нетипичная работа программ, подозрительные сообщения, обнаружение вредоносного ПО и т.п.), обязан:

- Немедленно прекратить работу с подозрительным объектом;
- Не выключать компьютер и не удалять файлы;
- Немедленно уведомить Подразделение ИБ по телефону или электронной почте;
- Зафиксировать время обнаружения и описание признаков инцидента.

2.4.2. Первичное реагирование:

Аналитик ГРИ в течение 30 минут после получения уведомления:

- Связывается с пользователем для уточнения деталей;
- Проводит первичный анализ ситуации;
- Определяет категорию и приоритет инцидента;
- Принимает решение о необходимости немедленных действий по локализации.

2.4.3. Локализация инцидента:

В зависимости от типа инцидента применяются следующие меры локализации:

- Заражение вредоносным ПО: отключение заражённой системы от сети, запуск полного антивирусного сканирования;
- Несанкционированный доступ: блокирование учётных записей, изменение паролей, анализ журналов доступа;
- Утечка информации: блокирование каналов передачи данных, изъятие носителей информации;

- Отказ в обслуживании: анализ сетевого трафика, блокирование атакующих IP-адресов, переключение на резервные системы.

2.4.4. Устранение последствий:

После локализации инцидента Администраторы ИСПДн выполняют:

- Удаление вредоносного ПО и восстановление целостности систем;
- Восстановление данных из резервных копий;
- Устранение уязвимостей, использованных при реализации инцидента;
- Проверку работоспособности информационных систем.

2.5. Регистрация и анализ инцидентов информационной безопасности

2.5.1. Все инциденты ИБ подлежат обязательной регистрации в Журнале регистрации инцидентов безопасности.

2.5.2. Аналитики ГРИ проводят детальный анализ каждого инцидента, включая:

- Определение способа реализации инцидента;
- Выявление использованных уязвимостей;
- Оценку причинённого ущерба;
- Определение круга затронутых субъектов и информационных ресурсов.

2.5.3. Результаты анализа оформляются в виде Отчёта о расследовании инцидента (Приложение 2) не позднее 5 рабочих дней с момента устранения инцидента.

2.6. Расследование инцидентов информационной безопасности

2.6.1. Расследование инцидентов Категории 1 и 2 проводится специальной комиссией, назначаемой приказом генерального директора.

2.6.2. В состав комиссии включаются:

- Представители Подразделения ИБ;
- Представители юридического отдела;
- Представители затронутых структурных подразделений;
- При необходимости — внешние эксперты.

2.6.3. Комиссия проводит:

- Сбор и анализ доказательств (журналы событий, файлы, носители информации);
- Опрос свидетелей и участников инцидента;
- Определение причин и обстоятельств инцидента;
- Выявление виновных лиц (при наличии);
- Разработку рекомендаций по предотвращению подобных инцидентов.

2.6.4. По результатам расследования комиссия готовит итоговый отчёт, который предоставляется генеральному директору Компании.

2.6.5. На основании отчёта принимаются решения о:

- Применении мер дисциплинарного воздействия к виновным лицам;
- Внесении изменений в организационно-распорядительные документы по ИБ;
- Внедрении дополнительных технических средств защиты;
- Проведении внепланового обучения персонала.

Раздел 3. Заключительная часть

3.1. Заключительные положения

3.1.1. Ответственность за выполнение правил настоящего Регламента несут все работники Компании, а также работники сторонних организаций, участвующих в эксплуатации и защите информационных ресурсов.
3.1.2. Контроль за выполнением данного Регламента осуществляет Ответственный за ИБ.
3.1.3. Пересмотр Регламента осуществляется не реже одного раза в три года, а также после каждого инцидента Категории 1.

Раздел 4. Приложения

Приложение 1

Форма Журнала регистрации инцидентов безопасности

№ п/п	Дата и время обнаружения	Источник информации	Описание инцидента	Категория	Приоритет	Затронутые системы	ФИО обнаружившего	Действия по реагированию	Статус
1	15.03.2026 10:30	Пользователь Иванов И.И.	Обнаружено вредоносное ПО на рабочей станции	2	2	АРМ бухгалтера	Иванов И.И.	Отключение от сети, антивирусное сканирование	Устранён

Приложение 2

Форма Отчёта о расследовании инцидента

Параметр	Содержание
Номер инцидента	2026-001
Дата и время обнаружения	15.03.2026 10:30
Дата и время устранения	15.03.2026 14:00
Категория инцидента	2 — Серьёзный инцидент
Описание инцидента	Обнаружение вредоносного ПО типа «троян» на рабочей станции бухгалтера

Способ реализации	Заражение через съёмный носитель информации
Использованные уязвимости	Отсутствие контроля подключения съёмных носителей
Причинённый ущерб	Временная недоступность рабочей станции (3,5 часа)
Затронутые ресурсы	АРМ бухгалтера, база данных «Бухгалтерия»
Виновные лица	Иванов И.И. (нарушение правил работы со съёмными носителями)
Рекомендации	1. Внедрить контроль подключения съёмных носителей 2. Провести внеплановое обучение персонала 3. Применить дисциплинарное взыскание к Иванову И.И.
ФИО и должность составителя отчёта	Петров П.П., аналитик ГРИ
Дата составления отчёта	20.03.2026

Утверждено: _____ (Подпись)

Дата: _____._____.20___ г.